

SENTINAL SECURITY ASSESSMENT REPORT

Project: Scope: NodeGoat | Type: COMBINED | Date: 2026-09-03 06:45 UTC

Overall Risk Score	Critical	High	Medium	Low	Total Findings
90.6/100	2	2	6	11	21

1. Executive Summary

****Security Assessment Executive Summary****

****Overall Posture:**** CRITICAL POSTURE

The automated assessment of <https://ginandjuice.shop> identified immediate critical exposures requiring urgent remediation. A total of 21 findings were recorded, including 2 Critical and 2 High severity vulnerabilities.

****Key Risk Highlights:****

- Total Discovered Findings: 21 (Critical: 2, High: 2, Medium: 6, Low: 11)
- Correlated Exploit Chains: 0
- Primary Concern Areas: Container Security, Vulnerable Dependency, Injection, Code Execution

Leadership is advised to authorize immediate sprint allocation for remediation of critical issues and enforce automated security gating in CI/CD pipelines.

3. Findings Inventory

Sev	Source	Vulnerability	Location / Remediation
MEDIUM	SAST	Dockerfile Container Running as Root Containers running as root increase the impact of container escape vulnerabilities.	OWASP-NodeGoat-c5cb68a/Dockerfile <i>Fix:</i> Add `USER nonroot` or a dedicated unprivileged user before the ENTRYPOINT/CMD.
HIGH	SAST	Potential NoSQL Injection Passing unvalidated `req.body` directly into MongoDB query operators allows authentication bypass and data extraction through	OWASP-NodeGoat-c5cb68a/app/data/allocations-dao.js <i>Fix:</i> Sanitize query keys using mongo-sanitize or enforce strict schema validation.
CRITICAL	SAST	Arbitrary Code Execution via eval() or Dynamic Function Invoking `eval()` or `new Function()` with dynamic strings evaluates untrusted JavaScript in the application runtime context	OWASP-NodeGoat-c5cb68a/app/routes/contributions.js <i>Fix:</i> Avoid `eval()` and `new Function()`. Use structured JSON parsers or declarative data structures.
MEDIUM	SCA	Vulnerable Dependency: debug (3.2.6) - GHSA-gxpj-cx7g-858c Vulnerability in decode-uri-component	OWASP-NodeGoat-c5cb68a/package-lock.json <i>Fix:</i> Upgrade decode-uri-component to a secure version. Upgrade to latest version.
MEDIUM	SCA	Vulnerable Dependency: body-parser (1.15.1) - GHSA-qwcr-r2fm-qrc7 Vulnerability in body-parser	OWASP-NodeGoat-c5cb68a/package.json <i>Fix:</i> Upgrade body-parser to a secure version. Upgrade to latest version.

HIGH	SECRETS	Exposed Secret: Database Connection String with Password Hardcoded secret token or credential (Database Connection String with Password) found in source code repository.	OWASP-NodeGoat-c5cb68a/README.md <i>Fix:</i> Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or
CRITICAL	SECRETS	Exposed Secret: Private Cryptographic Key Hardcoded secret token or credential (Private Cryptographic Key) found in source code repository.	OWASP-NodeGoat-c5cb68a/artifacts/cert/server.key <i>Fix:</i> Immediately revoke/rotate the leaked credential, remove it from git history using git-filter-repo or
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/ <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/blog <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/about <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/my-account <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/login <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.

LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/cart <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/product <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
LOW	DAST	Insecure Cookie Attribute (HttpOnly, Secure, SameSite) on 'AWSALB' The cookie 'AWSALB' is set without the HttpOnly, Secure, SameSite flag(s), allowing potential access via XSS or CSRF.	/catalog/product/stock <i>Fix:</i> Add HttpOnly, Secure, SameSite attributes to the Set-Cookie header.
MEDIUM	DAST	Missing Clickjacking Defense (X-Frame-Options / CSP frame-ancestors) The target web page does not enforce frame embedding restrictions, leaving users vulnerable to UI redressing (Clickjacki	/catalog/product/stock <i>Fix:</i> Set `X-Frame-Options: DENY` or `Content-Security-Policy: frame-ancestors 'none'`.
MEDIUM	WEB	Missing HTTP Strict Transport Security (HSTS) Header The HSTS header forces web browsers to communicate exclusively over encrypted HTTPS, mitigating SSL-stripping and man-in	/ <i>Fix:</i> Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` header to all HTTPS re
MEDIUM	WEB	Missing Content Security Policy (CSP) Header A Content Security Policy restricts sources of executable scripts, stylesheets, and frames, preventing Cross-Site Script	/ <i>Fix:</i> Implement a strong `Content-Security-Policy` header (e.g. `default-src 'self'; script-src 'self'; ob
LOW	WEB	Missing X-Content-Type-Options Header Setting `X-Content-Type-Options: nosniff` prevents browsers from MIME-sniffing a response away from the declared content	/ <i>Fix:</i> Configure `Permissions-Policy: camera=(), microphone=(), geolocation=()` to disable unused browser A
LOW	WEB	Missing Referrer-Policy Header The Referrer-Policy header controls how much referrer information (sent via the Referer header) should be included with	/ <i>Fix:</i> Configure `Referrer-Policy: strict-origin-when-cross-origin` or `no-referrer`.